

Case Study Main Points and Lessons

Alexis Mitchell

March 15, 2026

CSD380

Chapter 23 presents two case studies that demonstrate how organizations can maintain security and compliance in DevOps environments. Both examples show that traditional auditing and security practices often do not work well with modern development workflows. Instead, organizations must adapt by integrating compliance and monitoring directly into their development and operational processes.

The first case study, *Providing Compliance in Regulated Environments*, focuses on Bill Shinn, a principal security solutions architect at Amazon Web Services. Shinn explains that many auditors still rely on traditional auditing methods that were designed for physical IT environments. These methods often involve collecting screenshots or exporting configuration data into files, which does not work well in DevOps environments where systems are defined through code and change frequently. Because of this, teams needed to find better ways to demonstrate that their security controls were working.

To fix this, Shinn's team worked directly with auditors during the control design process instead of waiting until the audit stage. They used an iterative approach, focusing on one control per development sprint and determining what evidence would be required to prove that the control was effective. They also used telemetry systems such as Splunk or Kibana. This allowed auditors to retrieve the evidence they needed on demand instead of requiring developers to manually gather it. The main lesson from this case study is that compliance works more effectively when auditors work with development teams early and when audit evidence is automatically generated through monitoring systems.

The second case study, *Relying on Production Telemetry for ATM Systems*, starts with Mary Smith, a leader of a DevOps initiative in the consumer banking division of a large U.S. financial services organization. Smith observed that many security teams and auditors rely too heavily on code reviews to detect fraud. While code reviews and automated testing are

important, she argued that organizations should also rely on production monitoring to detect suspicious activity.

She described an incident where a developer inserted a backdoor into software used by ATM machines, allowing the machines to be placed into maintenance mode at certain times so cash could be withdrawn. Despite having safeguards such as separation of duties and change approval processes, the fraud still occurred. However, it was quickly discovered during an operations review meeting when someone noticed that several ATMs were entering maintenance mode at unscheduled times. The issue was detected through production telemetry before the regular cash audit process even occurred. The main lesson from this case study is that preventative controls alone are not enough; organizations must also rely on strong monitoring systems that can detect unusual behavior in real time.

Together, these case studies show that modern security and compliance practices must evolve to support DevOps environments. Collaboration with auditors, automated evidence collection, and strong production monitoring all help organizations maintain effective controls while still benefiting from the speed and flexibility of DevOps practices.